可変額送金可能なトークン型支払い方式の形式検証

児保 亮樹[1,a]　藤原 光真[1]　米山 一樹[1]　林田 淳一郎[2]　石井 龍[2]　佐古 健太郎[2]　永井 達也[2]
野村 健太[2]　渡邉 卓弥[2]　齋藤 恆和[2]　高田 雄太[2]　熊谷 裕志[2]　神薗 雅紀[2,3]

概要：電子決済は社会基盤として普及しているが，災害や通信障害等のオフライン環境下でも価値移転を継続できる決済手段が求められている．しかし，オフライン取引は二重支払いなどの不正を招きやすく，実運用に向けては不正検知や不正者追跡などの説明可能性の確保が不可欠である．林田ら（CSS2026）は，オフライン取引機能と説明可能性を両立する PKI を利用した中央集権的な可変額トークン型の電子決済方式を提案している．彼らの方式では，取引を署名付きトークンの生成として定義し，転々流通や分割送金により取引履歴を木構造として記録する．還収主体は記録された木構造に基づき不正検知を行う．標準化技術のみで構成できる一方，プロトコルの形式的な安全性評価は与えられていない．本稿では，暗号プロトコル自動検証ツール ProVerif を用い，林田らの方式の発行から分割送金，還収に至る一連のシーケンスの形式検証を行う．具体的には，トークンの木構造に基づく二重支払い検知アルゴリズムを複数の `table`を組み合わせて形式化し，偽造不可能性や二重支払い検知性などの安全性要件を還収経路の分離や排他制御を導入することによって形式化する．結果として，林田らの方式がすべての安全性を満たすことを示す．

Formal Verification of a Token-Based Payment Scheme Supporting Variable-Amount Transactions

Yoshiki Koyasu[1,a]　Kouma Fujiwara[1]　Kazuki Yoneyama[1]　Junichiro Hayata[2]　Ryu Ishii[2]
Kentaro Sako[2]　Tatsuya Nagai[2]　Kenta Nomura[2]　Takuya Watanabe[2]　Tsunekazu Saito[2]
Yuta Takata[2]　Hiroshi Kumagai[2]　Masaki Kamizono[2,3]

Abstract: Electronic payments have become widely adopted as a social infrastructure; however, there is a growing need for payment methods that can sustain value transfers even in offline environments. However, offline transactions are susceptible to fraud, such as double spending, making it essential for practical deployment to ensure explainability, including the detection of fraudulent transactions. Hayata et al. (CSS2026) propose a centralized, variable-amount token-based electronic payment scheme using PKI that achieves both offline transaction capability and accountability. Their scheme defines transactions as signed token generation, accumulating transaction histories in a tree structure through successive transfers and token splitting. Redeeming entities use this tree structure for algorithmic fraud detection. Although constructible with standardized technologies, formal security evaluation has not been conducted. In this paper, we formally verify the sequence from issuance to token splitting and redemption using the automated verification tool ProVerif. Specifically, we verify security properties including token unforgeability and double-spending detection.

1. はじめに

1.1 背景

電子決済サービスは必要不可欠な経済インフラとして定着している．しかし，主要な決済基盤は常時ネットワークに接続し，サーバ側で照会処理を行う設計を採用している．このようなシステムは，自然災害や大規模停電によって通

---

[1] 茨城大学
Ibaraki University
[2] デロイト トーマツ サイバー合同会社
Deloitte Tohmatsu Cyber LLC
[3] 一般社団法人デロイト トーマツ戦略研究所
Deloitte Tohmatsu Strategy Institute
[a] 26nm734l@vc.ibaraki.ac.jp

信が遮断された際に，決済機能そのものが完全に停止してしまう脆弱性を持つ．したがって，あらゆる状況下で経済活動を維持するためには，オフライン環境下であっても価値の移転を継続できる堅牢な仕組み（オフライン取引）が不可欠である．

一方，オフライン取引では，システムによる即時的な正当性の承認が行えない．この性質上，悪意のある利用者が単一のデジタルデータを複数回使用する二重支払いを，システム的に完全に防ぐことは困難である．そのため，オフライン取引を社会インフラとして導入するためには，不正行為を未然に防ぐアプローチだけでなく，事後的な対応プロセスを構築することが重要となる．

さらに，実用的な決済システムを構築するためには，決済額が固定された方式ではなく，利用者が任意の金額を指定して送金できる柔軟性が求められる．しかし，支払い額と釣銭を分ける可変額方式を採用した場合，転々流通の過程でトークンの分割処理が繰り返され，取引履歴が複雑な木構造を形成することになる．このような証跡データが複雑化する状況においても，正確に不正を検知，追跡できる論理的な仕組みが不可欠である．

1.2 先行研究と課題

電子決済方式は，価値の管理形態であるアカウント型とトークン型，およびシステムの管理主体である中央集権型と非中央集権型という二つの観点から分類できる．残高を台帳で管理するアカウント型は二重支払いの防止が容易である反面，管理主体によって取引関係が観測されるため，プライバシー保護の観点で課題が残る．一方，分散台帳などを基盤とする非中央集権型は可変額取引に対応した手法も存在するが，秘匿性を確保するための暗号処理や通信の負荷が大きく，法的要件への適合といった実運用上の課題を抱えている．

オフライン取引を目的としたアプローチとしては，中央集権型のトークン方式に関する先行研究 [1] が存在する．しかし，この方式はトークンの金額を一定に固定する設計を採用している．金額固定型の方式は取引時に適切な釣銭を生成することが困難であり，利用者が十分な資産を保有していても決済が完了しない状況が発生し得るなど，利便性に課題を残している[*1]．

林田ら [2] は標準的な暗号技術と公開鍵基盤を利用した中央集権的な可変額トークン型決済方式を提案している．彼らの方式は，送金のたびにトークンを支払い分と釣銭分に分割して新たな署名を付与し，その転々流通の履歴を木構造として記録する設計をとる．この木構造データを還収時に証跡として用いることで，オフラインでの可変額決済と事後的な不正検知アルゴリズムを両立させている．

しかし，林田らの方式は可変額送金に伴ってトークンの分割が繰り返されるため，取引履歴が複雑な木構造となり，プロトコルが取り得る状態の組合せが膨大になる．よって，設計上の見落としや予期せぬ攻撃経路が存在しないことを人手による検証のみで確かめることは容易ではない．方式の安全性を厳密に評価するためには，形式手法を用いた検証を行うことが有効である．

本稿では，形式手法に基づく暗号プロトコル自動検証ツールである ProVerif [3] に注目する．ProVerif は，Dolev-Yao [4] モデルに基づいて，メッセージや暗号プリミティブを記号に理想化して検証する暗号プロトコルの安全性自動検証ツールである．ProVerif は，TLS 1.3 [5], Bluetooth [6] といった広く普及した暗号プロトコル規格の安全性評価において多数の実績を有している．また，トークン型電子現金方式においても，奥田ら [7] が中央銀行デジタル通貨（CBDC）への適用を見据えた方式に対して二重使用検知やプライバシーに関する形式検証を行っており，決済方式の設計評価における有効な手段として認知されている．本稿ではこれらの知見に基づき，林田らの方式に対して ProVerif を用いた形式検証を行い，その安全性を明らかにすることを目的とする．

1.3 貢献

本稿では，林田らが提案した可変額送金可能なトークン型の電子決済方式について，暗号プロトコルの自動検証ツールである ProVerif を用いて形式検証を行う．本稿の具体的な貢献は以下の通りである．

- トークンの発行からオフライン環境下での分割送金，および発行機関への還収に至る一連のシーケンス，ならびに還収されたトークンの木構造を用いた二重支払い検知アルゴリズムを形式化する．
- 可変額送金可能なトークン型の電子決済方式が満たすべき安全性要件として，秘匿性，偽造不可能性，二重支払い検知性，免責性，ロンダリング耐性，取引公平性，および弱匿名性を形式化する．
- 上記の安全性要件を検証し，すべての要件を満たしていることを示す．

1.4 形式化の技術的概要

本稿の形式化では，送金のたびにトークンが支払い分と釣銭分に分割されるため，金額の加減算を扱う必要がある．そこで，親トークンの金額から支払額・釣銭額が一意に定まる関数と，それらの正しい組合せのみを受理する全域判定関数を導入することで，攻撃者による任意の金額の

[*1] 最小単位の金額のトークンのみを用いることで釣銭の発生を回避する運用も考えられるが，取引ごとに多数のトークンを扱う必要があり，トークンの分割によって釣銭を実現する方式とは異なるアプローチである．

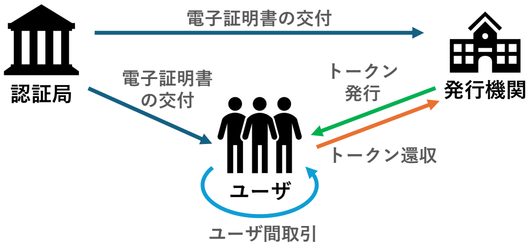

図 1　システムの全体図

組合せも含めて分割の正当性を判定できるようにした．さらに，二重支払い検知アルゴリズムが前提とするハッシュ値を主キーとするデータベースを，ProVerif の `table`を用いて再現する必要がある．これに対しては，トークンデータ自体をテーブルに記録し，対象のトークンを親に持つレコードをテーブルから検索することで子トークンの個数を判定できるようにした．加えて，複数の還収処理が並行してテーブルへアクセスすることによる競合を排他制御により回避し，木構造の分岐制約を `axiom`として与えることで，過剰近似に起因する偽の反例を排除した．

2.　林田らの可変額トークン型支払い方式

本稿で形式検証の対象とする林田らの方式は，オフライン取引と不正発生時の追跡可能性の両立を目的とし，公開鍵基盤に基づく中央集権型の電子決済モデルを採用している．本システムは図 1 に示すような，一般の利用者であるユーザ，トークンの発行および事後的な監査を担う発行機関，そして各主体に電子証明書を交付する認証局という 3 種類のエンティティから構成される．

各参加主体は，あらかじめ認証局から X.509 形式の公開鍵証明書とそれに対応する秘密鍵の交付を受け，安全に管理していることを前提とする．加えて，認証局および発行機関の公開鍵と証明書が各ユーザの端末内に初期値として安全に保持されている状況を想定する．システム上での取引では，各エンティティは互いの証明書の有効性を確認し合う相互認証を実施する．一方，オフライン取引では，端末間の近距離通信を用いた局所的な相互認証にとどめ，証明書の失効状態の厳密な確認はネットワーク復帰後の事後処理として実行される運用を想定している．

2.1　トークンのデータ構造

本方式において取引の媒体となるトークンは，単一のデータではなく，署名が付与された一連のデータの集合として定義される．ユーザ間で送金処理が行われるたびに，トークンは支払い分と釣銭分に分割され，それらの分岐履歴が木構造を形成しながら内部に記録されていく．具体的に，ある時点のトークン t は以下の要素を含むタプル $(v, pk_{own}, N, prev, st, \sigma)$ として表現される．

- v: トークンが保有する可変の金額データ．
- pk_{own}: トークンの所有者公開鍵．
- N: トークン生成のセッションごとに割り当てられる乱数値．
- $prev$: トークンが生成される元となった親トークンの情報．
- st: トークンの現在の用途を示す状態フラグ．初期を示す INIT，支払いを意味する PAY，釣銭を表す CHG の 3 種類が存在する．
- σ: 上記のデータ群に対する署名値．

発行機関からユーザへ直接交付された直後の初期トークンは，それ以前の流通履歴を持たない．そのため，初期トークンの $prev$ には親トークンのデータの代わりに，トークンを一意に識別するシリアル番号，発行機関の名称，および発行機関の公開鍵の情報が格納される仕様となっている．

2.2　脅威モデル

安全性評価における前提条件として，認証局および発行機関は定められた手順通りに動作するが，得られた情報から可能な限りの推測を試みるセミオネストな主体であると定義する．対照的に，一般のユーザはプロトコルの規約に縛られず，自身の利益のためにシステムの脆弱性を突く悪意ある主体として振る舞う可能性を考慮する．

2.3　トークン発行

ユーザと発行機関間の通信により実行される．

（1）**発行依頼:** ユーザはリプレイ攻撃を防ぐための乱数を生成し，希望するトークン金額の情報とともに発行機関へ送信する．

（2）**初期トークンの生成と送付:** 発行機関は，受信した乱数と金額，およびユーザの公開鍵に基づき，自身の秘密鍵を用いて初期トークンを生成する．生成の際，状態フラグには初期を示す値を設定し，親トークン情報には過去の履歴の代わりにトークンのシリアル番号，発行機関の名称，および発行機関の公開鍵といった初期情報を記録した上で，署名済みの初期トークンをユーザへ送信する．

2.4　トークン送金

送金者と着金者間の直接通信により実行される．

（1）**乱数の生成と共有:** 着金者は，取引セッションの同一性を担保しリプレイ攻撃を防止する目的で乱数を生成し，送金者へ送信する．

（2） **金額確認とトークン分割:** 送金者は，送金金額が保有トークンの金額を超過していないことを確認し，超過している場合は処理を中断する．超過がない場合，受信した乱数，送金金額，手元のトークン，および自身の秘密鍵を用いて，支払い用と釣銭用の新たな子トークンを生成する．新たに生成された両トークンの親トークン情報には，分割元となった親トークンのデータがそのまま格納される．

（3） **状態設定と送付:** 送金者は，支払い用トークンの状態フラグを支払いに設定して着金者の公開鍵を宛先情報として組み込み，釣銭用トークンの状態フラグを釣銭に設定して自身の公開鍵を宛先情報として組み込む．それぞれに自身の秘密鍵で電子署名を付与した後，支払い用トークンのみを着金者の端末へ送信し，釣銭用トークンは自身の端末内に保持する．

2.5 トークン検証および還収

トークンを受信した際の正当性検証，および発行機関による還収処理は以下の手順で実行される．

（1） **トークン検証:** トークンを受信した各エンティティは，初期トークンに至るまで親トークン情報を順に遡る．各階層において，親トークン情報から取得した公開鍵による署名検証，および子トークンの金額が親トークンの金額を超過していないことの確認を行う．状態フラグについては，受信したトークン自体が支払い，初期トークン以外の親トークンが支払いまたは釣銭，初期トークンが初期であることをそれぞれ確認する．

（2） **トークン還収:** ユーザは，保有するトークンを発行機関に対する全額支払い処理として送信する．発行機関は相互認証により送信者とトークン保有者の一致を確認した後，上記のトークン検証を実行する．検証に成功した場合，トークン還収通知をユーザへ送信し，還収したトークンを用いて後述の二重支払い検知アルゴリズムを実行する．

2.6 二重支払い検知

発行機関は，還収されたトークンの取引履歴をデータベース（DB）に記録し，木構造を復元することで二重支払いなどの不正を検知する．DB では，各トークンのハッシュ値を主キーとして以下の要素群が管理される．

- **金額:** 該当トークンが表す価値．
- **所有者の公開鍵:** 該当トークンの正当な権利者．
- **署名者の公開鍵:** 該当トークンに電子署名を付与したユーザ．
- **状態フラグ:** 発行，支払い，釣銭のいずれかの状態．
- **親トークンのハッシュ値:** 生成元となったトークンの識別子．
- **子トークンのハッシュ値の集合:** 該当トークンから分割生成されたトークン群の識別子．
- **還収済みフラグ:** 実際に発行機関へ還収されたトークンであるか（フラグを 1 とする），還収対象ではない還収トークンの祖先トークンであるか（フラグを 0 とする）を示す識別値．

発行機関は，上記の DB 構造を用いて以下の手順で不正を検知する．

（1） **還収対象トークンの確認:** 還収対象のトークンが DB に登録されているかを確認する．還収済みとして登録されている場合，または子トークン生成元として登録済みのトークン自体が還収された場合，当該トークンの送信者を不正者リストに追加する．未登録の場合は，該当情報を DB に新規登録する．

（2） **親トークンに遡って検証:** 対象トークンの葉から初期トークンに至るまで履歴を遡り，未登録の親トークンを順次 DB に登録する．この過程で，還収済みのトークンから新たな子トークンが生成されていることを検知した場合，親トークンの所有者を不正者リストに追加する．

（3） **分岐の整合性確認:** 親トークンに遡って検証すると同時に，親トークンから生成された子トークンの数と状態に基づきトークン木の整合性を確認する．

  - **子トークンが 3 個以上の場合:** 二重支払いと判定し，親トークンの所有者を不正者リストに追加する．
  - **子トークンが 2 個の場合:** 双方の状態フラグが同一である場合，または金額の合計が親の金額と一致しない場合，親トークンの所有者を不正者リストに追加する．
  - **子トークンが 1 個の場合:** 支払い用で親と所有者が同一の場合，釣銭用で所有者が異なる場合，または子トークンの金額が親トークンを上回る場合，親トークンの所有者を不正者リストに追加する．

3. ProVerif による形式化

本節では，林田らの方式を ProVerif を用いて安全性検証するため，まずデータ型の定義および暗号部品の形式化を行う．続いて，それらを用いてトークンの発行から送金，還収に至る一連のシーケンスを形式化する．さらに，方式が満たすべき安全性要件として，秘匿性，偽造不可能性，二重支払い検知性，免責性，ロンダリング耐性，取引公平性，弱匿名性の 7 つを定義し形式化を行う．

3.1 構成要素の形式化

林田らの方式で用いられるデータ型や構成要素の暗号部品について，以下のように形式化する．

3.1.1 基本的な情報の種類

本検証では，以下のデータ型を定義する．

- **通信路 (channel)**：エンティティ間でメッセージを送受信するための経路．発行機関とユーザ間，および各ユーザ間の 2 者間通信路をそれぞれ個別に定義する．
- **公開鍵 (pkey) と秘密鍵 (skey)**：電子署名の生成や検証，および公開鍵証明書の発行や検証に用いられる，互いに関連付けられた鍵のペア．
- **金額 (value)**：トークンが表す可変の金額.
- **乱数 (nonce)**：着金者がトークン生成のセッションごとに生成する値.
- **シリアル番号 (serial)**：初期トークンを一意に識別する値.
- **トークンの状態 (state)**：トークンの用途を示す状態フラグ．発行 `init`，支払い `pay`，釣銭 `change`の 3 つの定数を定義する．
- **受理通知 (notice)**：着金者による受理，および発行機関による還収の完了を通知するための定数.
- **メッセージの種類 (tag)**：プロトコル内でやり取りされるメッセージの種別を区別するための識別子．発行依頼や支払時のトークン送信など，メッセージごとに定数を定義し，メッセージと組にして扱う．

3.1.2 構成要素の暗号部品

各暗号部品は，以下の関数を用いて定義する．

- **公開鍵生成**：秘密鍵から対応する公開鍵を導出する関数．電子署名用の関数 `pk_sign`と公開鍵証明書発行用の関数 `pk_cert`とでそれぞれ異なる．
- **電子署名**：秘密鍵を用いてメッセージに署名を施す関数 `sign`と，署名を検証する関数 `sign_ver`．署名がある秘密鍵によって生成されたとき，その秘密鍵に対応する公開鍵と署名元のメッセージは検証に受理される．
- **公開鍵証明書**：認証局の秘密鍵を用いてある公開鍵に対して証明書を発行する関数 `cert`と，認証局の公開鍵を用いて証明書を検証する関数 `cert_ver`.
- **トークンの構成**：初期トークンを表すデータコンストラクタ `rootToken`と，送金により生成される子トークンを表すデータコンストラクタ `childToken`．前者は親トークン情報としてシリアル番号，発行機関名，発行機関の公開鍵を，後者は親トークンそのものを保持する．また，トークンの各フィールドを取り出す導出関数を定義する．
- **金額の分割**：親トークンの金額から支払額と釣銭額を導出する関数 `pay_part`，`change_part`と，2 つの子トークンの金額が同一の親トークンから正当に分割されたものであるかを判定する全域判定関数 `is_legit_split`.

このうち金額の分割については，具体的な数値の加減算ではなく，親トークンの金額から支払額・釣銭額が一意に定まるものとして表現する．正しい支払い・釣銭の組合せに対してのみ `true`を返す全域判定関数を導入し，加減算そのものをモデル化する代わりに，値の対応関係のみを判定することで，2 つの子トークンの金額が正当な分割であるかを，攻撃者による任意の値の組合せも含めて判定できる．

3.1.3 二重支払い検知用データベースの形式化

2.6 節で述べた二重支払い検知アルゴリズムは，トークンのハッシュ値を主キーとする DB を前提とするが，本稿ではこれを ProVerif の `table`を用いて表現する．具体的には，還収済みトークンおよびその履歴上の祖先トークンそのものを記録する `tokenDB`，各トークンの還収済みフラグに相当する `redeemed`，不正が検出された所有者の公開鍵を記録する `double_spend_pk`の 3 つのテーブルを用いる．DB に記録される 7 つのデータ（2.6 節参照）のうち，署名者の公開鍵は親トークン情報から，子トークンの集合は対象のトークンを親に持つレコードの検索から，それぞれ同等の情報が得られるため，テーブルにはトークンデータ自体を直接記録する．

なお，実際のプロトコル動作と形式化で異なる点として，子トークンの金額が親トークンの金額を超過していないことの確認は，親トークンの金額を `v`としたとき，子トークンの金額が `v`，`pay_part(v)`，`change_part(v)`のいずれかと一致することの確認に置き換えている．二重支払い検知において子トークンの金額が親トークンを上回る場合の判定も，これら 3 つのいずれとも一致しないことの確認として表現している．

3.2 シーケンスの形式化

ProVerif による形式化は，公開鍵基盤に基づく各エンティティの鍵生成から，トークンの発行，送金，および還収に至る一連のシーケンスを網羅している．図 2 に形式化したシーケンス例の全体の概略を，図 3 に対応するトークンの木構造を示す．発行機関はユーザ 1 に初期トークン T_1 を発行する．ユーザ 1 は T_1 を支払い用の T_2 と釣銭用の T_3 に分割し，T_2 をユーザ 2 へ送金して T_3 を自身の端末に保持する．ユーザ 2 は受け取った T_2 をさらに支払い用の T_4 と釣銭用の T_5 に分割してユーザ 3 へ T_4 を送金する一方，ユーザ 1 は保持していた釣銭 T_3 を分割せず全額その

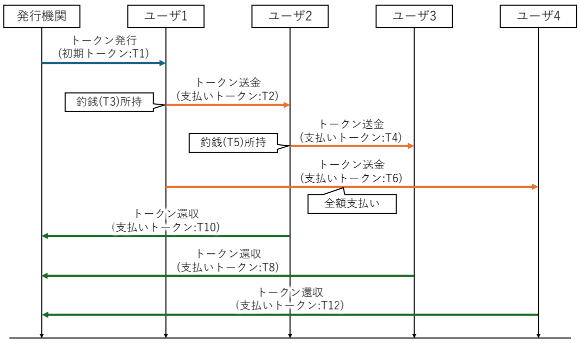

図 2　形式化したシーケンス例の全体像

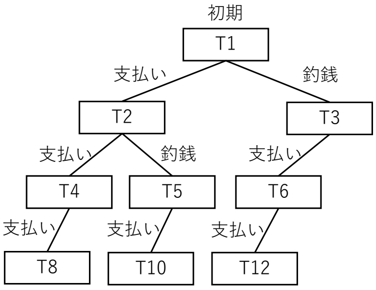

図 3　正当なユーザが取引するトークンの木構造

まま支払い用の T_6 としてユーザ 4 へ送金する．このように，深さ 2 のトークンに対して支払い・釣銭への分割送金と，分割を伴わない全額送金の双方が混在する状況をモデル化している．さらに深さ 3 では，T_4，T_5，T_6 のそれぞれが分割を伴わない全額送金により深さ 4 の T_8，T_{10}，T_{12} となり，これらが還収対象としてそれぞれ発行機関へ提出される．なお，トークンの番号は送金ごとに支払い用・釣銭用の順に割り当てており，全額送金では釣銭用トークンが生成されないため，T_7，T_9，T_{11} は欠番となる．

相互認証は，2 者間通信の初期段階で互いの公開鍵と証明書を交換・検証し，以降のメッセージには自身の秘密鍵で署名を付与する形に理想化して表現し，通信路は原則としてすべて攻撃者が介入可能な公開通信路としてモデル化する．ただし，弱匿名性を検証する場合に限り，2 者間の通信路を秘匿通信路とした上で，流通するすべてのトークンを公開通信路へ出力するモデルを用いる．正当なユーザが還収に出すトークンチェーンの長さは深さ 4 に固定し，深さ 2 の送金処理では全額支払いと支払い・釣銭分割の双方が混在するようサブプロセスを用意している．また，還収メッセージはすべて同一の通信路に流すことで，任意の順序でトークンが還収される状況を表現している．

上記のとおり正当なユーザが還収するトークンを深さ 4 に固定しているため，正当なユーザのみが取引するモデルでは，還収済みのトークンやその祖先トークンが再度還収される状況が生じず，二重支払い検知アルゴリズムにおける還収済みフラグに関する判定を検証できない．そこで，メインプロセスにおいて攻撃者用の鍵ペアと証明書を生成して公開通信路へ流出させることで，秘密鍵の漏洩や認証の破綻を伴わずに正規の手続きだけを悪用する攻撃者を表現し，還収済みのトークンが重ねて還収される状況を含めて検証できるようにした．

3.3　安全性要件の形式化

2.2 節で述べた脅威モデルのもと，可変額送金可能なトークン型の電子決済方式が満たすべき安全性要件として以下を定義し，ProVerif のクエリを用いて形式化を行う．

- **秘匿性:** 通信の過程において，各エンティティの秘密情報が攻撃者に漏洩しないこと
- **偽造不可能性:** 正当な権限を持たない攻撃者が検証を通過するトークンを生成できないこと
- **二重支払い検知性:** 攻撃者が同一の親トークンから不正な分岐を生成した場合に，発行機関の二重支払い検知アルゴリズムによって必ず不正が検知されること
- **免責性:** 正当なユーザが自身で署名していない不正な取引について，責任主体として誤判定されないこと
- **ロンダリング耐性:** 攻撃者が由来不明または不正な手法で生成したトークンを，被害者に正規のトークンとして受理させることができないこと
- **取引公平性:** 着金側がトークンの正しい着金処理について，その責任を逃れることがないこと
- **弱匿名性:** トークンの情報から，過去の取引に関与したユーザの身元を特定できないこと

なお，林田らの方式はトークンに所有者の公開鍵を直接記録する構成をとるため，奥田らの方式 [7] が満たしていた強匿名性（複数のトークンから同一の利用者による取引であることを識別できない）は満たさない．そのため，匿名性については上記の弱匿名性のみを要件として扱う．

秘匿性と弱匿名性は，攻撃者の到達可能性に関するクエリとして形式化する．前者は各エンティティの秘密鍵に対する `attacker`クエリとして，後者は身元情報と結び付く公開鍵証明書に対する `attacker`クエリとして記述する．

偽造不可能性，ロンダリング耐性，取引公平性は対応表明性のクエリとして形式化する．偽造不可能性は着金者や発行機関がトークンを受理するイベントに対して対応する送信イベントが先行して発生することを，ロンダリング耐性は受理したトークンに含まれる乱数が受理者自身の生成したものであり，かつ所有者が受理者自身であることを，取引公平性は送金者が着金者からの受理通知の検証に成功するイベントに対して着金者がトークンを受理するイベントが先行して発生することを，それぞれクエリとして記述する．取引公平性については，受理通知と着金処理の回数

を対応させるため，単射的な対応表明性を用いる．

これらのクエリでは，攻撃者が正規の鍵ペアと証明書を用いて手続きを行った場合を前提から除外する必要がある．深さ 2 の支払いにおける偽造不可能性のクエリを例に示す．

```
query pkU: pkey, init_token: bitstring,
      current_token: bitstring;
  event(accept_pay_token_D2(pkU,
        current_token, init_token)) ==>
    event(send_pay_token_D2(pkU,
        current_token, init_token))
    || event(corrupt(pkU)).
```

着金者がトークンを受理するイベント `accept_pay_token_D2` が発生した場合，そのトークンの直前の保有者 `pkU`自身が当該トークンを送信するイベント `send_pay_token_D2`が発生していることを要求する．ここで，`pkU`が攻撃者の公開鍵である場合，すなわちイベント `corrupt(pkU)`が発生している場合を加えることで，攻撃者が自身の正規の鍵ペアを用いて送金を行った場合を前提から除外している．

免責性は，二重支払い検知アルゴリズムがある公開鍵を不正者と判定するイベントが発生した場合に，その公開鍵が正当なユーザのいずれの公開鍵とも異なることを要求するクエリとして形式化する．

以下では，モデルの簡略化を必要とした偽造不可能性と，補助的な記述を必要とした二重支払い検知性において，それぞれの形式化に導入した技法について述べる．

3.3.1 偽造不可能性における経路の分離

深さ 3 のトークンに対する支払いの検証において，形式化モデルでは正当なユーザによる支払い経路が 2 つ存在する（U1→U2→U3 の経路と U1→U4 の経路）．両者を同一のモデル内で並行に検証しようとすると，ProVerif が 2 つの対称な経路上のトークンを混同してしまう問題が発生した．この問題に対し，検証対象としない経路については，その経路の相手ユーザが公開通信路へ出力する情報（乱数付き署名，受理通知，還収要求）だけをそのまま出力する処理に置き換える方針をとった．すなわち，U1→U2→U3 経路の偽造不可能性を検証する際には，経路に関与しない U4 の処理を，正直な U4 が本来出力するメッセージのみを供給する処理に簡略化し，逆に U1→U4 経路の検証時には U3 を同様に簡略化する．このように経路ごとに検証対象を分離することで，双方の経路について独立に偽造不可能性を検証する．

3.3.2 二重支払い検知性における排他制御と不変条件の公理化

二重支払い検知性は，二重支払い検知を通過した異なる 2 つのトークンが，(i) 初期トークンが異なる，(ii) 初期トークンが同一であり深さ 2 の分岐で支払いと釣銭に状態が分かれている，(iii) 深さ 2 までのトークンが同一であり深さ 3 の分岐で支払いと釣銭に状態が分かれている，のいずれかを満たすことを，検知を通過したトークンに対するイベント `double_spend_check_passed`を用いたクエリとして定義する．これは，同一の親トークンから正当な支払い・釣銭以外の形で複数の子トークンが生成されたにもかかわらず，その両方が検知を通過するという反例が存在しないことを意味する．

この形式化では，以下の 2 点に対応する必要がある．第一に，ProVerif の `table`は複数のプロセスから並行にアクセス可能であるため，2 つの還収処理が同時に実行されると，一方の登録処理が完了する前にもう一方が同じトークンの登録判定を行い，DB への二重登録という状態が生じうる．この問題を回避するため，還収処理全体を秘匿通信路 `lock`を用いた排他制御で囲み，処理の先頭で `lock`からトークンを受け取り末尾で次のプロセスへ引き渡すことで，DB への登録・判定処理が単一のプロセスによって逐次的に実行されることを保証した．

第二に，ProVerif は `table`の状態間に成り立つ不変な関係を自動的には推論できず，過剰近似により偽の反例が報告される場合がある．そこで，2 つの通過済みトークンの間に成り立つべき条件を `axiom`として明示的に与えた．与えた公理は，同一の初期トークンを持つ場合と同一の親トークンを持つ場合の 2 つであるが，`axiom`ではトークンの構造をデータコンストラクタによって展開して記述する必要があり，両者は展開の深さが異なるのみで同じ形をとる．そのため，以下では前者のみを示す．

```
axiom ...
 event(double_spend_check_passed(childToken(
  V_T, pk_T, N_T, childToken(V_Tp, pk_Tp, N_Tp,
  initTok, state_Tp, S_Tp), state_T, S_T))) &&
 event(double_spend_check_passed(childToken(
  V_T2, pk_T2, N_T2, childToken(V_Tp2, pk_Tp2,
  N_Tp2, initTok, state_Tp2, S_Tp2), state_T2,
      S_T2)))
 ==> (state_Tp <> state_Tp2)
  || ((V_Tp, pk_Tp, N_Tp, S_Tp)
     = (V_Tp2, pk_Tp2, N_Tp2, S_Tp2));
```

すなわち，同一の初期トークン `initTok`を先祖に持つ 2 つの通過済みトークンについて，それぞれの深さ 2 の親を比較したとき，両者は状態が相違するか，あるいは金額，所有者，乱数，署名のすべてが一致するかのいずれかであることを公理として与えている．これらの公理は，二重支払い検知アルゴリズムが実装上保証する木構造の制約（同一の親から生成される支払い用・釣銭用トークンは，それぞれ高々 1 つずつしか正当には存在し得ない）をモデルに明示的に与えるものであり，ProVerif の公式サンプルで用いられているテーブルの排他性に関する定式化と同様の記述である．

4. 検証結果

前節で形式化した 7 つの安全性要件について，ProVerif による検証を実行した．検証結果を表 1 に示す．いずれについても，林田らの方式が要件を満たすことを確認した．ただし免責性については，ProVerif の出力自体は `cannot be proved`であり，報告されたトレースが実際には起こり得ない偽の攻撃であることを確認した上で要件を満たすと判断している．以下，各結果が意味するところを述べる．

表 1 各安全性要件の検証結果

安全性要件	検証結果
秘匿性	True
偽造不可能性	True
二重支払い検知性	True
免責性	Cannot be proved（偽攻撃）
ロンダリング耐性	True
取引公平性	True
弱匿名性	True

秘匿性：攻撃者がすべての通信路を観測し，かつ正規の鍵ペアと証明書を保持して手続きに参加できる状況下においても，認証局，発行機関および各ユーザの秘密鍵に到達不可能である．

偽造不可能性：発行，支払，還収の各段階において，受理イベントに対応する送信イベントが必ず先行して発生すること，および受理されたトークンに含まれる初期トークンが発行機関によって正規に発行されたものである．

二重支払い検知性：検知アルゴリズムを通過した任意の 2 つのトークンが，同一のトークンであるか，初期トークンが異なるか，あるいは分岐において支払いと釣銭に状態が分かれているかのいずれかを満たす．

免責性：正当なユーザの公開鍵が不正者として判定されるトレースが報告された．これは，ProVerif がプロセスを Horn 節へ抽象化する際に同一セッション内での入力と出力の対応関係を保存しないため，正当なユーザによる署名生成が任意の宛先・乱数について適用可能な導出規則として扱われ，同一の親トークンから複数の支払い用トークンが生成されたかのように見なされることによる．実際のプロトコル実行では，送金者は着金者から受信した 1 つの乱数に対して支払い用・釣銭用のトークンを 1 組しか生成しないため，このような導出は生じ得ない．したがって，報告されたトレースはツールの近似に起因する偽の攻撃であり，正当なユーザが不正者として誤判定されることはなく，免責性は満たされる．

ロンダリング耐性：受理されるトークンが，着金者自身が当該セッションで生成した乱数と自身の公開鍵を含み，かつ相互認証した送信者自身によって送信されたものである．したがって攻撃者は，他のセッションや他者宛に生成されたトークンを正規のトークンとして被害者に受理させることができない．

取引公平性：送金者が受理通知の検証に成功した場合に，着金者による受理が必ず先行して行われている．これにより，着金者は着金の事実を否認できず，送金者が保持する受理通知が着金の証跡として機能する．

弱匿名性：攻撃者が各ユーザの公開鍵証明書に到達不可能である．これは，トークンには所有者の公開鍵のみが記録され，身元情報と結び付く公開鍵証明書は相互認証時にのみ交換されるという構成によるものであり，攻撃者がトークンデータ自体を入手した場合であっても，そこから過去の取引に関与したユーザの身元を特定できないことを意味する．

5. おわりに

本稿では，林田らが提案した可変額送金可能なトークン型電子決済方式について，暗号プロトコル自動検証ツール ProVerif を用いた形式検証を行った．トークンの発行から分割送金，還収に至る一連のシーケンスと，還収されたトークンの木構造を用いた二重支払い検知アルゴリズムを形式化し，秘匿性，偽造不可能性，二重支払い検知性，免責性，ロンダリング耐性，取引公平性，弱匿名性の 7 つを安全性要件として定義した．検証の結果，林田らの方式がこれら 7 つの安全性要件をすべて満たすことを明らかにした．本稿における検証結果は，標準化技術のみを用いてオフライン取引と説明可能性を両立するという林田らの方式の安全性を裏付けるものである．

参考文献

[1] 荒川幸寛, 奥田哲矢, 齋藤恒和, Mehdi Tibouchi, 阿部正幸. トークン型電子現金方式の central bank digital currency (CBDC) への適用可能性に関する初期検討. In *SCIS*, 2022.

[2] 林田淳一郎, 石井龍, 佐古健太郎, 永井達也, 野村健太, 渡邉卓弥, 齋藤恒和, 高田雄太, 熊谷裕志, 神薗雅紀. 転々流通および可変額送金可能なトークン型支払い方式. In *CSS*, 2026.

[3] ProVerif. `https://bblanche.gitlabpages.inria.fr/proverif/`.

[4] Danny Dolev and Andrew Yao. On the security of public key protocols. *IEEE Transactions on Information Theory*, Vol. 29, No. 2, pp. 198–208, 2003.

[5] Karthikeyan Bhargavan, Bruno Blanchet, and Nadim Kobeissi. Verified models and reference implementations for the tls 1.3 standard candidate. In *2017 IEEE Symposium on Security and Privacy (SP)*, pp. 483–502, 2017.

[6] Jianliang Wu, Ruoyu Wu, Dongyan Xu, Dave Jing Tian, and Antonio Bianchi. Formal model-driven discovery of bluetooth protocol design vulnerabilities. In *2022 IEEE Symposium on Security and Privacy (SP)*, pp. 2285–2303. IEEE, 2022.

[7] 奥田哲矢, 荒井研一, 齋藤恒和, 千田浩司, 中林美郷, 山村和輝, 宮澤俊之, 阿部正幸. トークン型電子現金方式の二重使用検知およびプライバシーに関する形式検証の考察. CSEC 研究会, Vol. 2023-CSEC-100, No. 66, 2023.